Comprendre Burp Suite

Explication simple pour debutants

Important : utilisez Burp Suite uniquement sur des sites **qui vous appartiennent** ou avec une **autorisation ecrite**. Pour vous entrainer legalement, la Web Security Academy de PortSwigger propose des laboratoires gratuits.

1. A quoi sert Burp Suite ?

Quand vous ouvrez un site web, votre navigateur envoie des **demandes** (appelees *requetes*) et le site renvoie des **reponses**. Normalement, vous ne voyez pas ces messages.

Burp Suite se place **au milieu** : il vous permet de **voir** ces messages, de les **modifier** et de les **renvoyer**. C'est utile pour comprendre comment un site fonctionne et verifier sa securite.

Image a retenir : c'est comme un facteur qui vous laisserait lire chaque lettre avant qu'elle n'arrive.



Le trafic passe par Burp avant d'atteindre le site.

2. Les mots a connaitre

Mot	Explication simple
Requete	Le message envoye par votre navigateur au site (ex. : "donne-moi cette page").
Reponse	Le message renvoye par le site.
Proxy	Un intermediaire entre votre navigateur et le site. Burp joue ce role.
GET / POST	GET sert a demander une page. POST sert a envoyer des donnees (ex. : un formulaire).
Code 200	Tout s'est bien passe.
Code 302	Le site vous redirige vers une autre page.
Code 403 / 404	Acces interdit / page introuvable.

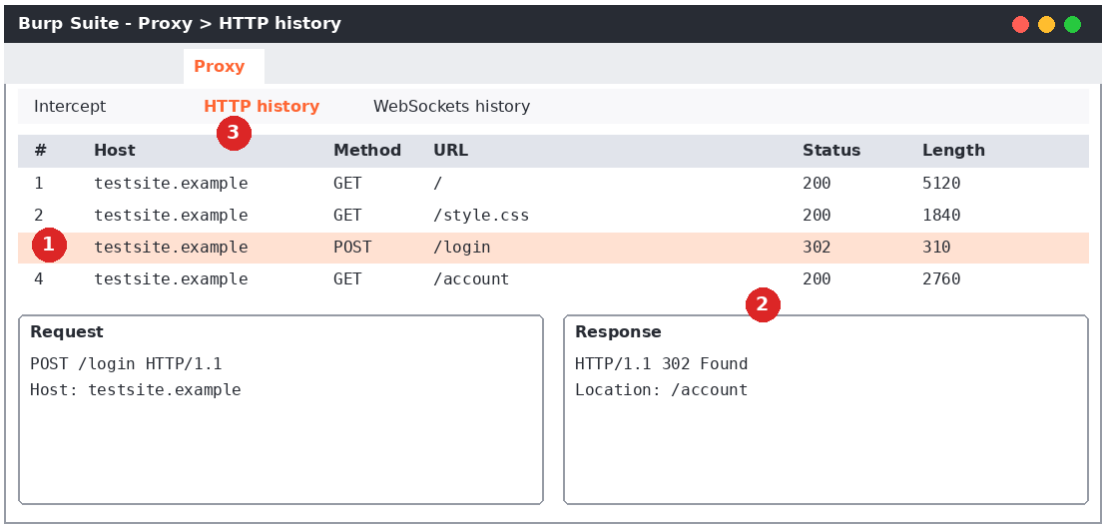
3. Les onglets importants

Burp est organise en onglets, en haut de la fenetre. Pour debuter, **trois suffisent** : Proxy, HTTP history et Repeater.

Proxy : l'onglet principal

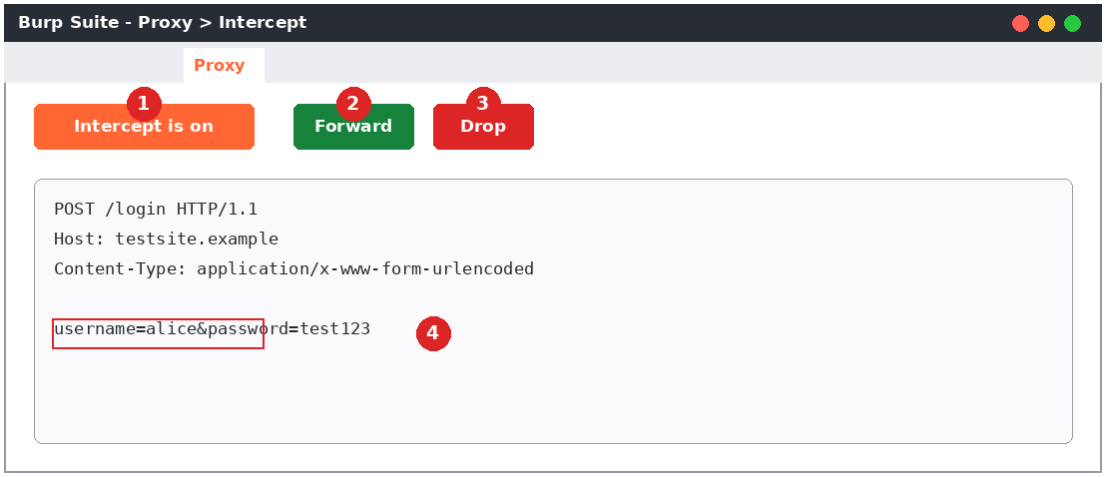
C'est le coeur de Burp. Il contient deux parties utiles :

- **HTTP history** : la liste de tout ce que votre navigateur a envoye. Cliquez sur une ligne pour lire la requete (a gauche) et la reponse (a droite).
- **Intercept** : quand il est sur **on**, Burp met chaque requete en pause avant de l'envoyer. Vous choisissez alors **Forward** (envoyer) ou **Drop** (supprimer). Laissez-le sur **off** la plupart du temps.



HTTP history : 1 = une requete, 2 = ses details, 3 = les colonnes (methode, adresse, code).

Ma capture d'ecran reelle : collez-la ici (voir le schema ci-dessus pour savoir quoi capturer).



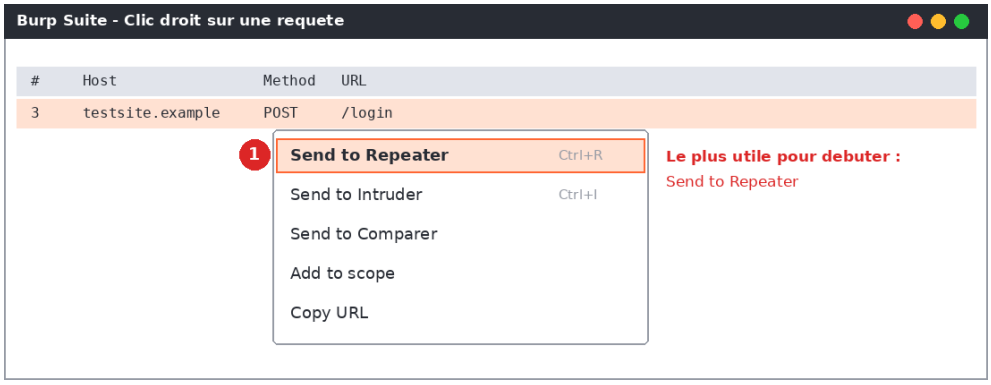
Intercept : 1 = activer/desactiver, 2 = Forward, 3 = Drop, 4 = valeur que l'on peut modifier.

Ma capture d'ecran reelle : collez-la ici (voir le schema ci-dessus pour savoir quoi capturer).

Si le navigateur reste bloque et n'affiche plus rien, c'est que **Intercept is on** est reste active. Cliquez sur Forward ou repassez sur **Intercept is off**.

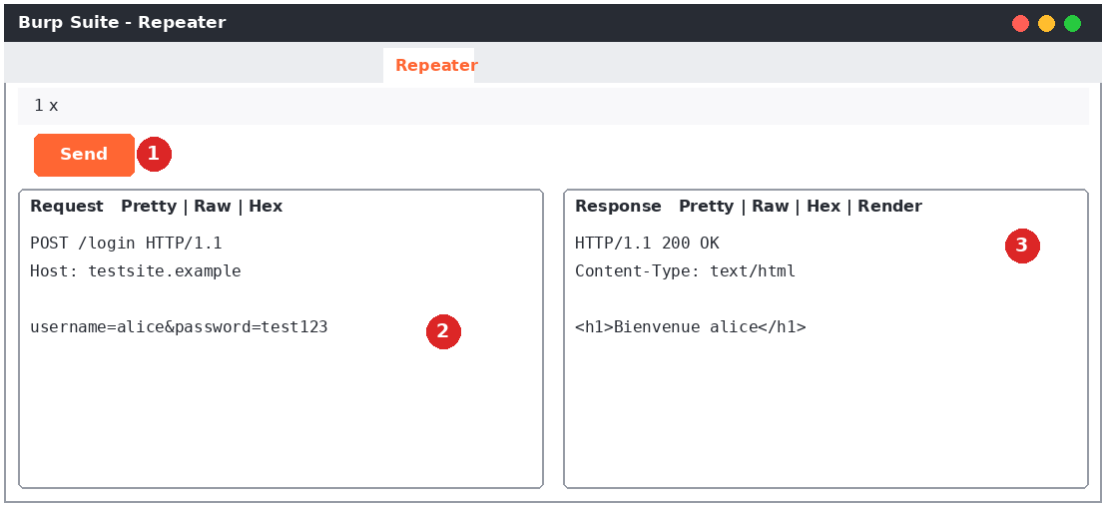
Repeater : modifier et renvoyer

Repeater permet de prendre une requete, de la **modifier**, puis de la **renvoyer** autant de fois que vous voulez en regardant la reponse. Pour y envoyer une requete : faites un **clic droit** dessus dans HTTP history, puis **Send to Repeater** (ou Ctrl+R). Modifiez ensuite la requete a gauche et cliquez sur **Send** : la reponse apparait a droite.



Le clic droit : Send to Repeater.

Ma capture d'ecran reelle : collez-la ici (voir le schema ci-dessus pour savoir quoi capturer).



Repeater : 1 = Send, 2 = la requete, 3 = la reponse.

Ma capture d'ecran reelle : collez-la ici (voir le schema ci-dessus pour savoir quoi capturer).

Les autres onglets (a decouvrir plus tard)

Onglet	A quoi il sert
Target	Carte du site : les pages et dossiers rencontres. Permet aussi de definir votre cible autorisee (le *scope*).
Decoder	Encode et decode des textes (Base64, URL...) pour les rendre lisibles.
Intruder	Envoie automatiquement beaucoup de variantes d'une requete. Tres limite dans la version gratuite.
Comparer	Compare deux requetes ou deux reponses.
Extensions	Ajoute des fonctions supplementaires.

4. Le navigateur integre

Le plus simple pour debuter : dans **Proxy**, cliquez sur **Open browser**. Burp ouvre un navigateur deja regle pour passer par lui. Tout ce que vous faites dedans apparait dans HTTP history. Pas besoin de configuration.

Burp ecoute par defaut sur l'adresse **127.0.0.1**, port **8080**.

5. Bonnes habitudes

- Ne travaillez que sur des sites **autorises**.
- Gardez **Intercept is off** par defaut.
- Modifiez **une seule chose a la fois** dans Repeater pour comprendre l'effet.